

TESTE DE PERFIS / RBAC

Aluno · Personal · Administrador

Método 1 Dia de Cada Vez

Procedimento seguro — sem abrir rules, sem debug e sem bypass de autenticação.

Item	Status
Data	18 de setembro de 2026
Projeto Firebase	metodo1dia-app (CLI autenticado)
Rules alteradas	Não
Modo debug / guest / bypass	Não
Contas de teste criadas nesta sessão	Não — UID pendente no Console
RBAC no código e nas rules	Modelo correto
Veredito de teste real	PENDÊNCIAS até criar as 3 contas e anotar os UIDs

1. Como o projeto define os papéis

Não há custom claims. A autorização real está no Firestore. Flags no documento users sozinhas não bastam para Admin Técnico.

Papel	users.role	Flags	Fonte de verdade no servidor
Aluno	student	isAdmin false · isPersonalTrainer false	Cadastro público sempre nasce aluno. Create bloqueia flags privilegiadas.
Personal	trainer	isPersonalTrainer true	Campo privilegiado em users/{uid}. Cliente comum não grava (noPrivilegedFields).
Admin Técnico	technical_admin	isAdmin true e isPersonalTrainer true	Coleção admins/{uid}. Sem esse documento o app não eleva, mesmo com isAdmin no perfil.

Arquivos

- lib/core/auth/user_role.dart — enum, resolveUserRole, RolePermissions, whitelist Personal.
- lib/features/auth/data/auth_repository.dart (~126–154) — lê admins/{uid} no login.
- firebase/firestore.rules — isAdmin(), isPersonalTrainer(), noPrivilegedFields, catch-all deny.
- lib/features/admin/data/roles_admin_repository.dart — setUserRole / createUser.
- functions/src/index.js — adminManageUser (só quem já está em admins/{uid}).
- lib/core/router/app_router.dart — redirect de /admin, /painel-personal e /personal-trainer/*.

2. Onde a informação fica

- Firestore users/{uid} — perfil, role, isPersonalTrainer, isAdmin (espelho).
- Firestore admins/{uid} — membership canônica do Admin Técnico.
- Não usa custom claims.
- Não existe coleção staff separada. Staff = admin OU users.isPersonalTrainer == true.
- O primeiro Admin não pode ser criado pelo app. Bootstrap: Console Firebase / Admin SDK.

3. Procedimento seguro para as 3 contas

E-mails sugeridos (complete o domínio se preferir outro): teste.aluno@metodo1dia.app · teste.personal@metodo1dia.app · teste.admin@metodo1dia.app. Senhas só no Console. Não gravar no Git.

Caminho A — já existe um Admin Técnico

- Entrar com a conta Admin existente.
- Abrir Painel Técnico → Usuários e papéis.
- Criar as 3 contas pelo fluxo oficial (Cloud Function adminManageUser).
- Aluno = student. Personal = trainer. Admin = technical_admin + admins/{uid}.
- Não alterar nenhuma outra conta.

Caminho B — bootstrap (ainda não há Admin)

- Authentication → Users → Add user: criar as 3 contas e-mail/senha e anotar o UID.
- Firestore users/{uid-aluno}: role student, isAdmin false, isPersonalTrainer false.
- Firestore users/{uid-personal}: role trainer, isAdmin false, isPersonalTrainer true.
- Firestore users/{uid-admin}: role technical_admin, isAdmin true, isPersonalTrainer true.
- Obrigatório: criar admins/{uid-admin} com { uid, role: technical_admin }.
- Aluno não promover. Personal só a conta de teste Personal. Admin só a conta de teste Admin.

Nesta sessão as contas não foram criadas. UIDs só existem depois do Console.

4. Telas que cada perfil pode acessar

Perfil	Pode	Não pode
Aluno	Login, home, treinos, hidratação, alimentação/IA, vídeos, áudios, perfil, desafio, consultoria/anamnese próprias, logout.	/admin, /painel-personal, gestão /personal-trainer/*. Em /personal-trainer vê a área do aluno, não o dashboard da Personal.
Personal	Login, dashboard Personal, alunos vinculados, anamnese, agenda, inbox, /painel-personal, whitelist /admin/videos, ebooks, áudios, Amanda, Lily.	/admin (painel técnico), /admin/users, cupons, criar/bloquear Admin, alterar rules.
Admin	Tudo da Personal + /admin, usuários e papéis, cupons, catálogo, configurações administrativas, logout.	Promover a si mesma para baixo. Bloquear a própria conta.

5. Checklist ALUNO

- ☐ login
- ☐ home
- ☐ treinos
- ☐ hidratação
- ☐ alimentação/IA
- ☐ vídeos
- ☐ áudios
- ☐ perfil
- ☐ não acessa Personal (dashboard / CMS)
- ☐ não acessa Admin (/admin)
- ☐ logout

6. Checklist PERSONAL

- ☐ login
- ☐ área Personal
- ☐ alunos autorizados
- ☐ anamnese
- ☐ agenda
- ☐ conteúdo permitido (CMS / vídeos / Amanda)
- ☐ não acessa funções exclusivas de Admin (/admin, usuários, cupons)
- ☐ logout

7. Checklist ADMIN

- ☐ login
- ☐ painel administrativo
- ☐ gerenciamento permitido
- ☐ usuários
- ☐ conteúdos
- ☐ configurações administrativas
- ☐ logout

8. VEREDITO RBAC — PENDÊNCIAS

O modelo no código e nas rules está correto: aluno não se promove; Personal e Admin só via Admin Técnico, Console ou Admin SDK. As 3 contas de teste ainda não existem com UID confirmado. O teste real dos checklists fica pendente até criar as contas e anotar os UIDs.

Conta	Onde configurar	UID	Papel
teste.aluno@...	Auth + users/{uid}	PENDENTE	Aluno / student
teste.personal@...	Auth + users.isPersonalTrainer	PENDENTE	Personal / trainer
teste.admin@...	Auth + users + admins/{uid}	PENDENTE	Admin Técnico